

Unit 7: Formative Discussion: Security Audit'

Formative Discussion: Security Audit of a Docker App on OpenVAS CE

Introduction

This security audit is assessing the Docker python-12factor-app application that was developed during Module 5 task, focusing on network-based vulnerability assessment using Greenbone's OpenVAS Community Edition OVA template that was downloaded and imported. The task instructed to use this tool to conduct a network vulnerability assessment and a report of detected vulnerabilities and their severity.

(Greenbone, 2026).

The docker container-based application was scanned using OpenVAS's so-called "Full and Fast scan" pre-defined template.

Figure 1: Definition of a Scan Target

Unit 7: Formative Discussion: Security Audit'

Name ↑	Type	Status ↑↓	Reports ↑↓	Last Report ↑↓	Severity ↑↓	Trend ↑↓	Actions
python-12factor-app (192.168.230.1)		Done	3	Thu, Sep 3, 2026 11:13 AM Coordinated Universal Time	N/A	→	     
 Target Unnamed Scanner Name OpenVAS Default Type OpenVAS Scanner Scan Config Full and fast Maximum concurrently executed NVTs per host 4 Maximum concurrently scanned hosts 20 Assets Add to Assets Yes Apply Overrides Yes Min QoD 70 % Scan Duration of last Scan a few seconds Auto delete Reports Do not automatically delete reports							

Unit 7: Formative Discussion: Security Audit'

The scan was completed without any vulnerabilities identified. All severity and impact indicators were clear, meaning that no noticeable weaknesses were identified within the tested scope. Nevertheless, the scanning results from OpenVAS do not indicate that Docker deployment is fully safe. OpenVAS largely relies on detection of network services and most probably not identify vulnerable packages that reside within the container images, exposed secret, insecure Dockerfile instructions, excessive capabilities, or vulnerable dependencies only if those are externally detectable. Container security research identifies these as significant risks.

(Jarkas et al., 2025).

Figure 2: OpenVAS Scan Results



Date ↓	Status ↑↓	Task ↑↓	Severity ↑↓	Critical ↑↓	High ↑↓	Medium ↑↓	Low ↑↓	False Pos. ↑↓
Thu, Sep 3, 2026 11:13 AM Coordinated Universal Time	Done	python-12factor-app	N/A	0	0	0	0	0

Therefore, an effective container security assessment requires a much more comprehensive approach. Network scanning should be mainly designed to identify network-level flaws and externally exposed services, they should be complemented by Docker image and dependency scanning, Dockerfile/configuration reviews, and host-level security checks and improved CI/CD processes, regularly scanning and updating container images for outdated components and known vulnerabilities, while hardening by removing packages and filtering ports, services. Also running containers

Unit 7: Formative Discussion: Security Audit'

with least privileges and capabilities, such as non-root-based operations, where appropriate.

(Docker, 2026).

These measures support ISO/IEC 27001:2022 Annex A controls 8.8 (Management of technical vulnerabilities), 8.9 (Configuration management) and 8.2 (Privileged access rights) standards.

The identification and treatment of technical vulnerabilities, secure configuration management, and control of privileged access.

(International Organization for Standardization (ISO), 2026).

This security audit report was designed to provide findings about docker application network exposure though it does not constitute a complete docker container security assessment. A fundamental limitation was that the application ran on another system, limiting the ability to assess internal container configuration using OpenVAS's network scanner.

(Ajith et al., 2024)

References

- Docker (2026) Docker Engine security. Available at:
<https://docs.docker.com/engine/security/> [Accessed: 3 September 2026].
- Greenbone (2026) OPENVAS SCAN – GOS 25 user manual. Available at:
<https://docs.greenbone.net/GSM-Manual/gos-25.0/en/> [Accessed: 3 September 2026].

Unit 7: Formative Discussion: Security Audit'

- International Organization for Standardization (ISO) (2026) ISO/IEC 27001:2022, Information security management systems. Available at: <https://www.iso.org/standard/27001> [Accessed: 3 September 2026].
- Jarkas, O., Ko, R., Dong, N. and Mahmud, R., (2025). A container security survey: Exploits, attacks, and defenses. *ACM Computing Surveys*, 57(7), pp.1-36.
- Ajith, V., Cyriac, T., Chavda, C., Kiyani, A.T., Chennareddy, V. and Ali, K., (2024). Analyzing docker vulnerabilities through static and dynamic methods and enhancing iot security with aws iot core, cloudwatch, and guardduty. *IoT*, 5(3), pp.592-607.

Use of Digital Tools

This document has been produced exclusively for educational purposes. Referenced content, copyrights, and trademarks, remain the sole property of the respective owner. ChatGPT 5.5 was used for some proofreading and clarity as well as literature exploration, language refinement, coding and programming techniques research. All academic writing, analysis, argumentation, and conclusions represent the original work of the author. AI tools were used for exploration, same way as academic literature exploration. No AI-generated content or code was directly copied into the final submission. Any use of content mentioned in this document is properly referenced to its original author and was used responsibly to ensure integrity and originality. All academic writing, analysis, argumentation, and conclusions represent my original work. I have used Artificial Intelligence responsibly and ethically, in accordance with the assignment brief. All AI use has been declared and evidenced.